

See discussions, stats, and author profiles for this publication at: <https://www.researchgate.net/publication/326381217>

BlendCAC: A BLockchain-ENabled Decentralized Capability-based Access Control for IoTs

Conference Paper · July 2018

DOI: 10.1109/Cybermatics_2018.2018.00191

CITATIONS

232

READS

1,164

4 authors:



Ronghua Xu

Michigan Technological University

94 PUBLICATIONS 2,498 CITATIONS

SEE PROFILE



Yu Chen

Binghamton University

317 PUBLICATIONS 6,853 CITATIONS

SEE PROFILE



Erik Blasch

United States Air Force Research Laboratory

1,010 PUBLICATIONS 22,960 CITATIONS

SEE PROFILE



Genshe Chen

Intelligent Fusion Technology, Inc.

486 PUBLICATIONS 7,533 CITATIONS

SEE PROFILE

BlendCAC: A BLockchain-ENabled Decentralized Capability-based Access Control for IoTs

Ronghua Xu, Yu Chen
Binghamton University, SUNY
Binghamton, NY 13902, USA
{rxu22, ychen}@binghamton.edu

Erik Blasch
US Air Force Research Laboratory
Rome, NY 13441, USA
erik.blasch@gmail.com

Genshe Chen
Intelligent Fusion Technology, Inc.
Germantown, MD 20876, USA
gchen@intfusiontech.com

Abstract—The prevalence of Internet of Things (IoT) allows heterogeneous embedded smart devices to collaboratively provide smart services with or without human intervention. While leveraging the large-scale IoT-based applications like Smart Grid or Smart Cities, IoT also incurs more concerns on privacy and security. Among the top security challenges that IoT face, access authorization is critical in resource sharing and information protection. One of the weaknesses of today's access control (AC) is the centralized authorization server, which can be the performance bottleneck or the single point of failure. In this paper, BlendCAC, a blockchain-enabled decentralized capability-based AC is proposed for the security of IoTs. The BlendCAC aims at an effective access control processes to devices, services and information in large scale IoT systems. Based on the blockchain network, a capability delegation mechanism is suggested for access permission propagation. A robust identity-based capability token management strategy is proposed, which takes advantage of a smart contract for registration, propagation and revocation of the access authorization. In the proposed BlendCAC scheme, IoT devices are their own master to control their resources instead of being supervised by a centralized authority. Implemented and tested on a Raspberry Pi device and on a local private blockchain network, the experimental results demonstrate the feasibility of the proposed BlendCAC approach to offer a decentralized, scalable, lightweight and fine-grained AC solution to IoT systems.

Index Terms—Blockchain, Smart Contract, Decentralized Access Control (DAC), Internet of Things (IoT).

I. INTRODUCTION

Thanks to the proliferation of the Internet of Things (IoT), more and more smart devices are connected to the Internet at an unprecedented scale. The prevalence of the IoTs changes human activities by pervasively providing applications and services revolutionizing transportation, healthcare, industrial automation, and emergency response [6]. These capabilities enable both situational awareness (SAW) and information fusion based on uninterrupted, ubiquitous, real-time data flows, which provide essential contextual information for delay-sensitive, mission-critical applications [9], [11], [12], [29].

While benefiting from the large-scale applications like Smart Grid and Smart Cities, highly connective smart IoT devices with insufficient security enforcement incur more concerns on security and privacy. Security issues, such as privacy, authentication, access control, system configuration, information storage and management, are among the top challenges in today's IoT environment [7].

One of the top security concerns that IoTs face is access control (AC). Access authorization is particularly critical in resource and information protection. Conventional AC approaches, such as the Access Control List (ACL), the Role-based Access Control (RBAC) and the Attribute-based Access Control (ABAC), have been widely used in IT systems. However, they are not able to provide a scalable, manageable and efficient mechanism to meet new challenges raised by IoT networks:

- 1) *Scalability*: The fast growing number of devices and services also pose increasing management workload to AC systems. AC strategies are expected to be able to handle the scalability problem resulting from the large scale IoT networks.
- 2) *Heterogeneity*: IoT systems normally integrate heterogeneous computing nodes and other physical devices with variant underlying technologies or in different application domains, and each domain or platform has its own specific requirements for identity authentication and authorization policy enforcement.
- 3) *Causality*: The traditional RBAC and ABAC systems envisage planned and long-lived patterns, while the IoT world is mainly characterized by short-lived, with causal and/or spontaneous interactions [17], in which the AC scheme is required to dynamically respond.
- 4) *Lightweight*: IoT devices are usually resource-constrained, which implies the lack of capability to support computing intensive tasks or large storage required applications. meanwhile, the smart devices connect to each other by low power and lossy networks. Consequently the AC protocols should be lightweight and not impose significant overhead on devices and communication networks.

The extraordinary large number of devices with heterogeneity and dynamics necessitate a more scalable, flexible and lightweight AC mechanism for IoT networks. In addition, a majority of the AC solutions rely on centralized authorities. Although the delegation mechanism helps migrate certain intelligence from the centralized cloud server to a near-site fog or edge network, the power of policy decision making and identity management is exclusively located in the cloud center. IoT networks need a new AC framework that provides decen-

tralized authentication and authorization schemes in trustless application network environments, such that intelligence could be diffused among large number of distributed edge devices.

While being well-known as the fundamental protocol of Bitcoin [22], the first digital currency, the blockchain protocol has been recognized as the potential to revolutionize the fundamentals of IT technology because of its many attractive features and characteristics such as supporting decentralization and anonymity maintenance [13]. In this paper, a *BLOCKchain-ENabled, Decentralized, Capability-based Access Control* (BlendCAC) scheme is proposed to enhance the security of IoTs. It provides a scalable, fine-grained, and lightweight AC solution to protect smart devices, services and information in IoT networks. An identity-based capability token management strategy is presented and the authorization delegation mechanism is illustrated. A capability-based access validation process is implemented on service providers that integrate situational awareness (SAW) and customized contextualized conditions. Experimental results demonstrate the feasibility and effectiveness of the proposed AC scheme.

The major contributions of this work are:

- 1) A complete architecture of capability-based authorization is proposed, which includes capability management, delegation propagation, and access right validation;
- 2) A proof of concept prototype based on smart contracts is implemented and deployed on a local private blockchain network; and
- 3) A comprehensive experimental study has been conducted that compares the proposed BlendCAC scheme with the well-known RBAC and ABAC models. The experimental results validate the feasibility of the BlendCAC scheme in IoT environments without introducing significant overhead.

The remainder of this paper is organized as follows: Section II analyzes and reviews the state of the art research in access control for IoT systems. Section III illustrates the details of the proposed BlendCAC system. Beside the implementation of the proof-of-concept prototype, Section IV reports an extensive experimental study using test scenarios that are run on both resource-constrained and non-resource-constrained devices. Finally, a summary is presented in Section V.

II. BACKGROUND KNOWLEDGE AND RELATED WORK

A. Access Control in IoTs

Technologies for authentication and authorization of access to certain resources or services are among the main elements to protect the security and privacy for IoT devices [24]. As a fundamental mechanism to enable security in computer systems, AC is the process that decides who is authorized to have what communication rights on which objects with respect to some security models and policies [15]. An effective AC system should satisfy the main security requirements, such as confidentiality, integrity, and availability. However, recently raised security and privacy issues in the era of IoTs require that AC systems should be built on principals of high scalability, flexibility, lightweight and causality.

There are various AC methods and solutions with different objectives proposed to address security challenges in IoTs. The Role-Based Access Control (RBAC) model [26] provides a framework that specifies user access authorization to resources based on roles, and supports principals such as least privilege, partition of administrative functions and separation of duties [25]. However, a pure RBAC model presents a role explosion problem, which is inappropriate to implement security policies that require interpreting complex and ambiguous IoT scenarios. The RBAC model implemented on IoTs adopts a Web of Things (WoTs) approach to implement AC policies on the smart objects via the web service [14], [30], and the RBAC model was extended by introducing context constraints to consider contextual awareness in AC decisions [37]. However, those proposals are not able to clearly specify the fine-grained AC on variant resources or services, like the mapping of the role notion and device-to-device communication.

To address the weaknesses of RBAC model in a highly distributed network environment, an Attribute-based Access Control (ABAC) [28], [36] is introduced in IoT networks to reduce the number of rules resulting from role explosion. In ABAC the AC policies are defined through directly associating attributes with subjects. An efficient authentication and ABAC based authorization scheme for the perception layer of IoTs have been proposed [35]. Based on user attribute certificates, an access right is granted by AC authority to ensure fine-grained access control. However, specifying a consistent definition of the attributes within a domain or across different domains could significantly increase effort and complexity on policy management as the number of devices grow, and hence, the attribute-based proposal is not suitable for large scale distributed IoT networks.

Due to drawbacks that exist in traditional access control models such as RBAC and ABAC, the requirements imposed by IoT scenarios are difficult to satisfy. Given many great advantages from an IoT perspective, such as scalability, flexibility, distributed, and user-driven; IoT systems can support delegation and revocation [24]. Capability-based access control approaches have been considered a promising solution to IoTs. The Access Control Matrix (ACM) model represents a good conceptualization of authorizations by providing a framework for describing discretionary access control (DAC) [25]. As two implementations of ACM, Access Control List (ACL) and Capability are widely used in authorization system. In the ACL model, each object is associated with an access control list that saves the subjects and their access rights for the objects.

The ACL is a centralized approach to support administrative activities with better traceability by implementing AC strategies on cloud servers [20]. However, as the number of subjects and resources increases, confused duty problems are identified in ACL and access rules become much more complex to manage. Due to the centralized management property, ACL cannot provide multiple levels of granularity, is not scalable and is vulnerable to single point of failure. Meanwhile, in the capability model (CapAC), each subject is associated with a

capability list that represents its access rights to all concerned objects. The CapAC has been implemented in many large scale IoT-based projects, like IoT@Work [16].

Although capability-based methods have been used as a feature in many access control solutions for the IoT-based applications, applying the original concept of capability-based access control model in IoT network has raised several issues, like capability propagation and revocation [15]. To tackle these challenges, a Secure Identity-Based Capability (SICAP) System is proposed, which enables the monitoring, mediating, and recording of capability propagations to enforce security policies as well as achieving rapid revocation capability by using an exception list [15]. However, the centralized access control server (ACS) becomes the performance bottleneck of the system, and the author didn't provide a clear illustration on security policy used in capability generation and propagation, neither was the context information in making authorization decision considered.

To enable contextual awareness in federated IoTs, an authorization delegation method is proposed based on a Capability-based Context-Aware Access Control (CCAAC) model [8]. By introducing a delegation mechanism to capability generation and propagation process, the CCAAC model shows great advantages to address scalability and heterogeneity issues in IoT networks. Given the requirement that a prior knowledge of the trust relationship among domains in federated IoTs must be established, however, the proposed approach is not suitable universally for all IoT application scenarios. Inspired by the SUN DIGITAL ECOSYSTEM ENVIRONMENT project [27], a capability-based access control (CapAC) model was proposed that adopted a centralized approach for managing access control policy [17]. However, the proposed CapAC scheme depended on a centralized authority and did not consider the lightweight requirement at the smart device side. To address the limitations in CapAC, a Distributed Capability-based Access Control (DCapAC) model was proposed, which was directly deployed on resource-constrained devices [18], [19]. The DCapAC allows smart devices to autonomously make decisions on access rights based on authorization policy, and it shows advantages in scalability and interoperability. However, capability revocation management and delegation were not discussed, neither were the granularity and context-awareness considered.

B. Blockchain and Smart Contract

The blockchain is a fundamental framework of Bitcoin [22], which was introduced by Nakamoto in 2008. The blockchain is the public ledger that allows the data be recorded, stored and updated distributively. By its nature, the blockchain is a decentralized architecture such that it does not rely on a centralized authority anymore. The transactions are approved and recorded in blocks by miners, and the blocks are appended to the blockchain in a chronological order. Blockchain uses consensus mechanism to maintain the sanctity of the data recorded on the blocks. Thanks to the trustless proof mechanism enforced through mining task on miners across

network, users can trust the system of the public ledger stored worldwide on many different decentralized nodes maintained by "miner-accountants," as opposed to having to establish and maintain trust with the transaction counter-party or a third-party intermediary [31]. Blockchain is the ideal architecture to ensure distributed transactions between all participants in a trustless environment.

Because of many attractive characteristics, blockchain technology has been investigated to offer a decentralized AC scheme in trustless network environments. A blockchain based AC is proposed to publish AC policy and to allow distributed transfer access right among users on bitcoin network [21]. The proposal allows distributed auditability, preventing a third party from fraudulently denying the rights granted by an enforceable policy. However, the solution still rely on an external centralized policy database to fetch access right given the links stored in the blockchain, and the experimental results are not provided. Based on blockchain technology, FairAccess is proposed to offer a fully decentralized pseudonymous and privacy preserving authorization management framework for IoTs [23]. In FairAccess, AC policies are enclosed in new types of transactions that are used to grant, get, delegate, and revoke access. However, the scripting language used in Bitcoin allows to transcode two types of AC policies, so that the proposed framework cannot support more complex and granular access control model.

Blockchain has shown its success in decentralization of currency and payments, like Bitcoin. Currently designing a programmable money and contracts, which support variety of customized transaction types become a trend to extend blockchain application beyond cryptocurrency. Smart contract, which emerges from the smart property, is a method of using blockchain to achieve agreement among parties, as opposed to rely on third parties for maintaining a trust relationship. By using cryptographic and other security mechanisms, smart contract combines protocols with user interfaces to formalize and secure relationships over computer networks [32]. Smart contract is essential a collection of defined instructions and data that have been recorded at a specific address of blockchain. Through encapsulating operational logic as a bytecode and performing Turing complete computation on distributed miners, a smart contract allows user to transcode more complex business models as new types of transactions on a blockchain network. Smart contract provides a promising solution to implement more flexible and fine-grained AC models on blockchain networks.

III. BLENDCAC: A BLOCKCHAIN-ENABLED DECENTRALIZED CAPAC

In order to address the issues discussed in Section II, the authors recently proposed a Federated Capability-based Access Control model (FedCAC) [33]. FedCAC addresses scalability, granularity, and dynamicity challenges in access control strategy for IoTs. Through delegating part of the identity authentication and authorization task to domain delegator, workload of the centralized policy decision making center

prime key for identifying entities' profile information. As each entity has at least one main account indexed by its address in the blockchain network, the blockchain is used to represent the VID for profiling register entities.

In general, the capability specifies which subject can access resources of a target object by associating subject, object, actions and condition constraints. The identity-based capability (ICap) structure is defined as follows:

$$ICap = f(VID_S) \rightarrow \{VID_O, D, AC, C\} \quad (1)$$

where the parameters are:

- f : a one-way hash mapping function to establish relation between subject and authorized access rights set;
- VID_S : the virtual ID of a subject that requests an access to a service or resource;
- VID_O : the virtual ID of an object that provides a service or resource;
- D : a set of delegation right, e.g., delegatee and delegation depth;
- AR : a set of access right for actions, e.g., read, write, execute; and
- C : a set of context awareness information, such as time, location.

In the BlendCAC system, an AR is defined as the access right set. For example, the AR can be $\{Read\}$, $\{Write\}$, $\{Read; Write\}$, or $\{NULL\}$. If $AR = \{NULL\}$, the operation conducted on the resource is not allowed. C is defined as a context constraints set, like $C = \{C1, C2\}$ or $C = \{NULL\}$. If $C = \{NULL\}$, no context constraint is considered in the access right validation process. The delegation privilege is defined in set D including *delegatee* and *delegation depth*. The *delegatee* is defined as an array to queue the delegated entity's address, and the *delegation depth* specifies the maximum delegate propagation times.

C. Capability-based Access Right Authorization

Given the defined BlendCAC structure, the capability token structure and the related operations are transcoded to a smart contract and deployed on the blockchain network, while the access right authorization is implemented as a policy-based decision making service running by the domain owner. As shown by Fig. 2, a comprehensive capability-based access right authorization procedure consists of four steps: capability generation, access right validation, capability delegation and revocation.

- 1) *Capability Generation*: As one type of meta data to represent the access right, the capability $ICap$ could be generated by associating a VID with an AR , thus the $ICap$ has the identified property to prevent forgery. After receiving access request from user, the domain owner generates capability token based on predefined access control policy, and launches transactions to save a new token data to a smart contract. A large number of $ICap$ is grouped into the capability pools on smart contract, which could be proofed and synchronized among the nodes across the blockchain network.

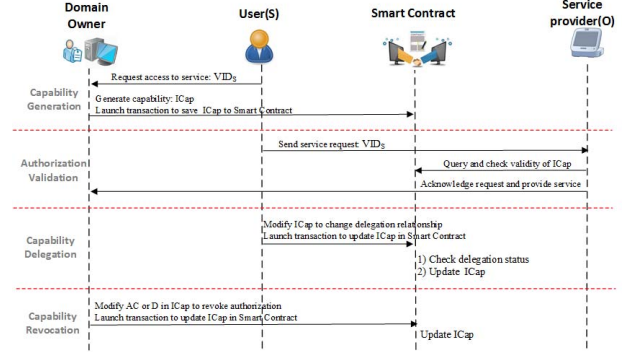


Fig. 2. Flowchart of the Capability-based Access Right Authorization.

- 2) *Access Right (AR) Validation*: After receiving the service request from a subject, the service provider first fetches the capability token from the smart contract by using the subject's address, then makes decision whether or not to grant an access to the service according to the local access control policy. Implementing access right validation at the local service provider allows smart objects to be involved in the AC decision making task, which is suitable to offer a flexible and fine-grained AC service in IoT networks.
- 3) *Capability Delegation*: In our proposal, the capability delegation mechanism is implemented by configuring delegation set D in the $ICap$. As the smart contract has received an update token transaction from the user, it checks the set D to validate the delegation right. If the value of *delegation depth* is more than the count of elements in *delegatee*, the user could delegate his/her capability token to other entity by appending the target address to *delegatee*. Otherwise, the capability delegation request is rejected. For each successful delegation transaction, the length of queue *delegatee* increases by 1 until reaches the limitation defined by the delegation depth.
- 4) *Capability Revocation*: The capability revocation considers two scenarios: delegation right D revocation and $ICap$ revocation. In our proposal, only the domain owner is allowed to perform revocation operation on a smart contract. In the delegation right revocation process, the domain owner could remove the addresses from *delegatee* to revoke the delegated access right for certain specific entities. In case of $ICap$ revocation, through changing *delegation depth* to zero or clearing the AR , the capability token becomes unavailable to all associated entities.

IV. IMPLEMENTATION AND EXPERIMENTAL RESULTS

A concept-proof prototype system has been implemented on a real private Ethereum blockchain network environment. Compared with other open blockchain platform, like Bitcoin and Hyperledger, Ethereum has a more matured ecosystem and is designed to be more adaptable and flexible for development

of smart contract and business logic [1]. The proposed BlendCAC model has been transcoded to a smart contract using Solidity [4], which is a contract-oriented, high-level language for implementing smart contracts. The access authorization and validation policy is enforced as a web service application based on the Flask framework [2] using Python. The Flask is a micro-framework for Python based on Werkzeug, Jinja 2 and good intentions. The lightweight and extensible micro architectures make the Flask a preferable web solution on resource constrained IoT devices.

In order to evaluate the performance and the overhead of our BlendCAC scheme, two benchmark models, RBAC and ABAC, are also implemented on the experimental web service system. All transcoded access control models have the similar data structure in smart contract except authorization representation. In RBAC smart contract, authorization is defined as the approach to bridge the relationship between user and permission, while RBAC smart contract uses user's attributes as representative format for authorization. Both the RBAC and ABAC need a local database, either to maintain the user-role-permission or to manage the attribute-permission policy for authorization validation process, the profiles and policy rules management are developed by using an embedded SQL database engine, called SQLite [5]. The lower memory and computation cost make the SQLite an ideal database solution to resource constrained system, like Raspberry Pi.

A. Environmental Setup

The mining task is performed on a system with stronger computing power, like a laptop or a desktop. Two miners are deployed on a laptop, of which the configuration is as follows: the processor is 2.3 GHz Intel Core i7 (8 cores), the RAM memory is 16 GB and the operating system is Ubuntu 16.04. And other four miners are distributed to four desktops which are empowered with the Ubuntu 16.04 OS, 3 GHz Intel Core TM (2 cores) processor and 4 GB memory. Each miner uses two CPU cores for mining. The IoT devices are two Raspberry Pi 3 Model B with the configuration as follows: 1.2GHz 64-bit quad-core ARMv8 CPU, the memory is 1GB LPDDR2-900 SDRAM and the operation system is Raspbian based on the Linux kernel. Unfortunately, the Raspberry Pi is not powerful enough to function as a miner, so two Raspberry Pi worked as nodes to join the private blockchain without mining. All devices use Go-Ethereum [3] as the client application to work on the blockchain network.

B. Performance Evaluation

In the test scenario, two Raspberry Pi 3 devices are adopted to play the roles of the client and the service provider respectively. To measure the general cost incurred by the proposed BlendCAC scheme both on the IoT devices' processing time and the network communication delay, 50 test runs have been conducted based on the proposed test scenario, where the client sends a data query request to the server for an access permission. This test scenario is based on an assumption that the subject has a valid capability token when it performs the

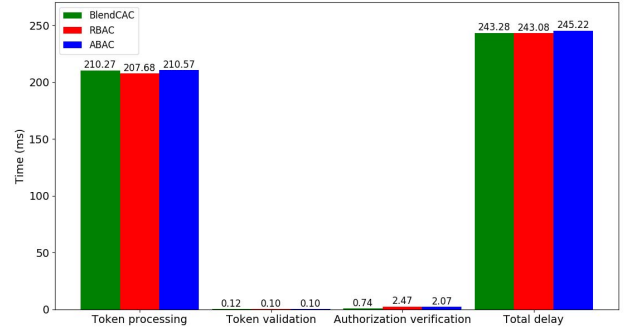


Fig. 3. Computation Time for Each Stage in BlendCAC.

action. Therefore, all steps of authorization validation must be processed on the server side so that the maximum latency value is computed.

1) *Computational Overhead*: According to the results shown in Fig. 3, the average total delay time (again over 50 runs) required by the BlendCAC operation of retrieving data from the client to server is 243 ms, which is almost the same as RBAC or ABAC does. The total delay includes the round trip time (RTT), time for querying capability data from the smart contract, time for parsing JSON data from the request, and time for access right validation. The token processing task is mainly responsible for fetching token data from the smart contract and introduces the highest workload among the authorization operation stages. Owing to the fact that encapsulating user-role relationship in the smart contract requires less data than the capability or attributes does, the RBAC incurred less computational cost than what BlendCAC and ABAC did in token processing stage. As the most computing intensive stage, the execution time of token processing is about 210 ms, which is accounted for almost 86% of the entire process time.

The entire authorization process is divided into two steps, token validation and authorization verification, where the average time of the authorization process is about 0.86 ms (0.12 ms + 0.74 ms). Compared with token validation process, which only simply checks the token valid status, the authorization verification process requires more computational power to enforce the local access control policies. Although the similarity in token data structure allows all the three access control models have almost the same time in the token validation stage, the BlendCAC outperforms the RBAC and ABAC in authorization verification. Since both the RBAC and ABAC needs a database to either manage user-role-permission relationship or maintain attributes-permission rules, which inevitably incurs time consuming on searching rules in database. In our experimental study, the RBAC (2.47 ms) and ABAC (2.07 ms) have much higher processing time than BlendCAC (0.74 ms).

2) *Communication Overhead*: Owing to the high overhead introduced by querying token data from the smart contract in token processing stage, a token data caching solution is introduced in the BlendCAC system to reduce network latency.

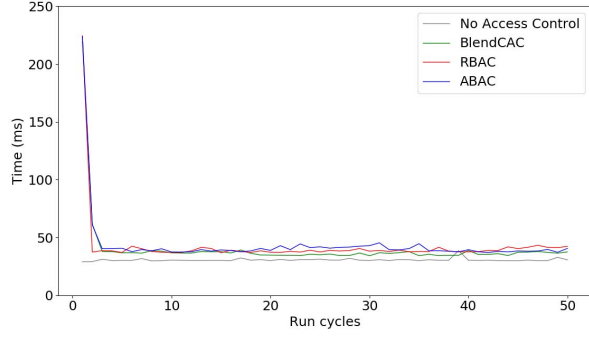


Fig. 4. Network Latency of BlendCAC.

When the client sends a service request to the server, the service side extracts cached token data from the local storage to valid authorization. The service providers regularly update cached token data by checking smart contract status. The token synchronization time is in consistence with block generation time, which is about 15 seconds in the Ethereum blockchain network. Simulating a regular service request allows us to measure how long it takes for the client to send a request and retrieve the data from the server.

Figure 4 shows the overall network latency incurred and compares the execution time of the BlendCAC with RBAC, ABAC and a benchmark without any access control enforcement. At the beginning, a long delay is observed in the first service request scenario, in which service provider communicated with the smart contract and cached the token data. However, through processing the local cached token data for authorization validation, the network latency decreases quickly and becomes stable at a low level during the subsequent service requests. The benchmark without access control enforcement takes an average of 31 ms for fetching requested data versus that the BlendCAC consumes on average of 36 ms. It means that the proposed BlendCAC scheme only introduces about 5 ms extra latency. The overhead in terms of delay is trivial. As shown by Fig. 4, the BlendCAC also has lower latency than RBAC and ABAC in most period of time. In addition, unlike RBAC and ABAC, which rely on the local policy database as intermediate to valid access right, encoding access right directly in capability token makes the BlendCAC more scalable and flexible in the large scale IoT networks.

As the experimental results show, the proposed BlendCAC scheme introduced a small amount of overhead, both at the network layer and the local device layer. To measure general network latency of inter-domain communication, HTTP is executed on the same testbed to simulate a regular transaction, like connects, sends a request and retrieves the reply. Compared with calculated average network latency that is about 300 ms, the trade-off in the proposed BlendCAC is acceptable for the network environments by only incurring 5 ms latency (no more than 2%). In addition, the test scenarios are based on Raspberry Pi devices, which belongs to a type of simple board computer (SBC) with limited computation power and memory space. It is reasonable to expect a better performance when the

BlendCAC scheme is implemented on more powerful smart devices, like a smart phone. Although synchronizing cached token data with the smart contract requires more computational resource, the transactions of querying smart contract status are regularly launched by the service providers in a separate service thread rather than being called in each service request, so that network overhead over service request communication is greatly reduced to improve QoS requirement.

C. Discussions

The experimental results demonstrate that the proposed BlendCAC strategy is effective and efficient to protecting the IoT devices from unauthorized access requests. Compared to centralized CapAC access models, the BlendCAC scheme has the following advantages:

- 1) *Decentralized authorization*: leveraging the blockchain technique, the proposed BlendCAC scheme allows domain owners to control their devices and resource without depending on a centralized third authority to establish the trust relationship with unknown nodes; instead, it could define a domain-specific access authorization policy, which is critical to the scalable, heterogeneous and dynamic IoT-based applications;
- 2) *Edge computing driven intelligence*: thanks to the blockchain technology, the BlendCAC scheme provides a device driven access control framework that is suitable for the distributed nature of IoT environments. Through transferring power and intelligence from the centralized cloud server to the edge of network, the risk of performance bottleneck and the single point of failure are mitigated, and the smart things are capable of protecting their own resource and privacy by enforcing user-defined security mechanism;
- 3) *Fine granularity*: enforcing access right validation on local service providers enables the smart devices to make decisions whether or not to grant access to certain services according to the local environmental conditions. Fine-grained access control with the less privilege access principle prevents privilege escalation, even if an attacker steals a capability token; and
- 4) *Lightweight design*: compared to the XML-based language for access control, such as XACML, JSON is a lightweight technology that is suitable for the resource constrained platforms. Given the experimental results, our JSON based capability token structure introduces small overhead on the computation and network performance.

V. CONCLUSIONS

In this paper, we proposed a decentralized capability-based access control framework leveraging the smart contract and blockchain technology, called BlendCAC, to handle the challenges in access control strategies for IoTs. A concept-proof prototype has been built in a physical IoT network environment to verify the feasibility of the proposed BlendCAC. The BlendCAC model is transcoded to smart contracts and works

on the private Ethereum blockchain network. The desktops and laptops serve as miners to maintain the sanctity of transactions recorded on the blockchain, while Raspberry PI devices act as edge computing nodes to access and to provide IoT-based services. Extensive experimental studies have been conducted and the results are encouraging. It validated that the BlendCAC scheme is able to efficiently and effectively enforce access control authorization and validation in a distributed, trustless IoT network. This work has demonstrated that our proposed BlendCAC framework is a promising approach to provide a scalable, fine-grained and lightweight access control for IoT networks.

While the reported work has shown great potential, there is still a long way towards a complete decentralized security solution for IoTs and edge computing. Deeper insights are expected. Part of our on-going effort is focused on further exploration of the blockchain based access control scheme in real-world applications. Taking the smart surveillance system as a case study, the proposed BlendCAC will be extended to protect network cameras and motion sensors in the novel urban surveillance platform we developed recently [10], [34].

REFERENCES

- [1] "Ethereum Homestead Documentation," <http://www.ethdocs.org/en/latest/index.html>.
- [2] "Flask: A Python Microframework," <http://flask.pocoo.org/>.
- [3] "Go-ethereum," <https://ethereum.github.io/go-ethereum/>.
- [4] "Solidity," <http://solidity.readthedocs.io/en/latest/>.
- [5] "SQLite," <https://www.sqlite.org/index.html>.
- [6] A. Al-Fuqaha, M. Guizani, M. Mohammadi, M. Aledhari, and M. Ayyash, "Internet of things: A survey on enabling technologies, protocols, and applications," *IEEE Communications Surveys & Tutorials*, vol. 17, no. 4, pp. 2347–2376, 2015.
- [7] F. A. Alaba, M. Othman, I. A. T. Hashem, and F. Alotaibi, "Internet of things security: A survey," *Journal of Network and Computer Applications*, vol. 88, pp. 10–28, 2017.
- [8] B. Anggorojati, P. N. Mahalle, N. R. Prasad, and R. Prasad, "Capability-based access control delegation model on the federated iot network," in *Wireless Personal Multimedia Communications (WPMC), 2012 15th International Symposium on*. IEEE, 2012, pp. 604–608.
- [9] E. Blasch, I. Kadar, L. L. Grewe, R. Brooks, W. Yu, A. Kwasinski, S. Thomopoulos, J. Salerno, and H. Qi, "Panel summary of cyber-physical systems (cps) and internet of things (iot) opportunities with information fusion," in *Signal Processing, Sensor/Information Fusion, and Target Recognition XXVI*, vol. 10200. International Society for Optics and Photonics, 2017, p. 1020000.
- [10] N. Chen, Y. Chen, E. Blasch, H. Ling, Y. You, and X. Ye, "Enabling smart urban surveillance at the edge," in *Smart Cloud (SmartCloud), 2017 IEEE International Conference on*. IEEE, 2017, pp. 109–119.
- [11] N. Chen, Y. Chen, S. Song, C.-T. Huang, and X. Ye, "Smart urban surveillance using fog computing," in *Edge Computing (SEC), IEEE/ACM Symposium on*. IEEE, 2016, pp. 95–96.
- [12] N. Chen, Y. Chen, Y. You, H. Ling, P. Liang, and R. Zimmermann, "Dynamic urban surveillance video stream processing using fog computing," in *Multimedia Big Data (BigMM), 2016 IEEE Second International Conference on*. IEEE, 2016, pp. 105–112.
- [13] M. Crosby, P. Pattanayak, S. Verma, and V. Kalyanaraman, "Blockchain technology: Beyond bitcoin," *Applied Innovation*, vol. 2, pp. 6–10, 2016.
- [14] L. M. S. De Souza, P. Spiess, D. Guinard, M. Köhler, S. Karnouskos, and D. Savio, "Socrades: A web service based shop floor integration infrastructure," in *The internet of things*. Springer, 2008, pp. 50–67.
- [15] L. Gong, "A secure identity-based capability system," in *Security and Privacy, 1989. Proceedings., 1989 IEEE Symposium on*. IEEE, 1989, pp. 56–63.
- [16] S. Gusmeroli, S. Piccione, and D. Rotondi, "Iot@ work automation middleware system design and architecture," in *Emerging Technologies & Factory Automation (ETFA), 2012 IEEE 17th Conference on*. IEEE, 2012, pp. 1–8.
- [17] S. Gusmeroli, S. Piccione, and D. Rotondi, "A capability-based security approach to manage access control in the internet of things," *Mathematical and Computer Modelling*, vol. 58, no. 5-6, pp. 1189–1205, 2013.
- [18] J. L. Hernández-Ramos, A. J. Jara, L. Marín, and A. F. Skarmeta, "Distributed capability-based access control for the internet of things," *Journal of Internet Services and Information Security (JISIS)*, vol. 3, no. 3/4, pp. 1–16, 2013.
- [19] J. L. Hernández-Ramos, A. J. Jara, L. Marín, and A. F. Skarmeta Gómez, "Dcapbac: embedding authorization logic into smart things through ecc optimizations," *International Journal of Computer Mathematics*, vol. 93, no. 2, pp. 345–366, 2016.
- [20] B. Liu, Y. Chen, A. Hadiks, E. Blasch, A. Aved, D. Shen, and G. Chen, "Information fusion in a cloud computing era: a systems-level perspective," *IEEE Aerospace and Electronic Systems Magazine*, vol. 29, no. 10, pp. 16–24, 2014.
- [21] D. D. F. Maesa, P. Mori, and L. Ricci, "Blockchain based access control," in *IFIP International Conference on Distributed Applications and Interoperable Systems*. Springer, 2017, pp. 206–220.
- [22] S. Nakamoto, "Bitcoin: A peer-to-peer electronic cash system," 2008.
- [23] A. Ouaddah, A. Abou Elkalam, and A. Ait Ouahman, "Fairaccess: a new blockchain-based access control framework for the internet of things," *Security and Communication Networks*, vol. 9, no. 18, pp. 5943–5964, 2016.
- [24] A. Ouaddah, H. Mousannif, A. A. Elkalam, and A. A. Ouahman, "Access control in the internet of things: big challenges and new opportunities," *Computer Networks*, vol. 112, pp. 237–262, 2017.
- [25] P. Samarati and S. C. de Vimercati, "Access control: Policies, models, and mechanisms," in *International School on Foundations of Security Analysis and Design*. Springer, 2000, pp. 137–196.
- [26] R. S. Sandhu, E. J. Coyne, H. L. Feinstein, and C. E. Youman, "Role-based access control models," *Computer*, vol. 29, no. 2, pp. 38–47, 1996.
- [27] G. D. Skinner et al., "Cyber security management of access controls in digital ecosystems and distributed environments," in *6th International Conference on Information Technology and Applications (ICITA 2009)*, 2009, pp. 77–82.
- [28] W. W. Smari, P. Clemente, and J.-F. Lalande, "An extended attribute based access control model with trust and privacy: Application to a collaborative crisis management system," *Future Generation Computer Systems*, vol. 31, pp. 147–168, 2014.
- [29] L. Snidaro, J. Garcia-Herrera, J. Llinas, and E. Blasch, *Context-Enhanced Information Fusion*. Springer, 2016.
- [30] P. Spiess, S. Karnouskos, D. Guinard, D. Savio, O. Baecker, L. M. S. De Souza, and V. Trifa, "Soa-based integration of the internet of things in enterprise services," in *Web Services, 2009. ICWS 2009. IEEE International Conference on*. IEEE, 2009, pp. 968–975.
- [31] M. Swan, *Blockchain: Blueprint for a new economy*. O'Reilly Media, Inc., 2015.
- [32] N. Szabo, "Formalizing and securing relationships on public networks," *First Monday*, vol. 2, no. 9, 1997.
- [33] R. Xu, Y. Chen, E. Blasch, and G. Chen, "A federated capability-based access control mechanism for internet of things (IOTs)," in *the SPIE Defense & Commercial Sensing 2018 (DCS), Conference on Sensors and Systems for Space Applications*. SPIE, 2018.
- [34] R. Xu, S. Y. Nikouei, Y. Chen, S. Song, A. Polunchenko, C. Deng, and T. Faughnan, "Real-time human object tracking for smart surveillance at the edge," in *the IEEE International Conference on Communications, Selected Areas in Communications Symposium Smart Cities Track*. IEEE, 2018.
- [35] N. Ye, Y. Zhu, R.-c. Wang, R. Malekian, and L. Qiao-min, "An efficient authentication and access control scheme for perception layer of internet of things," *Applied Mathematics & Information Sciences*, vol. 8, no. 4, p. 1617, 2014.
- [36] E. Yuan and J. Tong, "Attributed based access control (abac) for web services," in *Web Services, 2005. ICWS 2005. Proceedings. 2005 IEEE International Conference on*. IEEE, 2005.
- [37] G. Zhang and J. Tian, "An extended role based access control model for the internet of things," in *Information Networking and Automation (ICINA), 2010 International Conference on*, vol. 1. IEEE, 2010, pp. V1–319.